

Task 3-Output

```
Microsoft Windows [Version 10.0.26200.8328]
(c) Microsoft Corporation. All rights reserved.

C:\Users\91769>cd C:\Users\91769\Downloads\CodeAlpha_SecureCodeReview

C:\Users\91769\Downloads\CodeAlpha_SecureCodeReview>python -m pip install bandit
Defaulting to user installation because normal site-packages is not writeable
Requirement already satisfied: bandit in c:\users\91769\appdata\roaming\python\python310\site-packages (1.9.4)
Requirement already satisfied: PyYAML>=5.3.1 in c:\users\91769\appdata\roaming\python\python310\site-packages (from bandit) (6.0.3)
Requirement already satisfied: stevedore>=1.20.0 in c:\users\91769\appdata\roaming\python\python310\site-packages (from bandit) (5.7.0)
Requirement already satisfied: colorama>=0.3.9 in c:\users\91769\appdata\roaming\python\python310\site-packages (from bandit) (0.4.6)
Requirement already satisfied: rich in c:\users\91769\appdata\roaming\python\python310\site-packages (from bandit) (15.0.0)
Requirement already satisfied: markdown-it-py>=2.2.0 in c:\users\91769\appdata\roaming\python\python310\site-packages (from rich->bandit) (4.2.0)
Requirement already satisfied: pygments<3.0.0,>=2.13.0 in c:\users\91769\appdata\roaming\python\python310\site-packages (from rich->bandit) (2.20.0)
Requirement already satisfied: mdurl<=0.1 in c:\users\91769\appdata\roaming\python\python310\site-packages (from markdown-it-py>=2.2.0->rich->bandit) (0.1.2)

[notice] A new release of pip available: 22.3.1 -> 26.1.1
[notice] To update, run: python.exe -m pip install --upgrade pip

C:\Users\91769\Downloads\CodeAlpha_SecureCodeReview>python -m bandit -r vulnerable_app.py -o bandit_report.txt -f txt
[main] INFO    profile include tests: None
[main] INFO    profile exclude tests: None
[main] INFO    cli include tests: None
[main] INFO    cli exclude tests: None
[main] INFO    running on Python 3.10.18
[text] INFO    Text output written to file: bandit_report.txt

C:\Users\91769\Downloads\CodeAlpha_SecureCodeReview>type bandit_report.txt
Run started:2026-05-14 12:48:01.344043+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
Severity: Low  Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist\_imports.html#b404-import-subprocess
Location: .\vulnerable_app.py:8:0
7      import sqlite3
```

```
8      import subprocess
9      import hashlib

-----
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'admin123'
Severity: Low  Confidence: Medium
CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105\_hardcoded\_password\_string.html
Location: .\vulnerable_app.py:17:11
16     USERNAME = "admin"
17     PASSWORD = "admin123"
18     SECRET_KEY = "mysecretkey2024"

-----
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'mysecretkey2024'
Severity: Low  Confidence: Medium
CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105\_hardcoded\_password\_string.html
Location: .\vulnerable_app.py:18:13
17     PASSWORD = "admin123"
18     SECRET_KEY = "mysecretkey2024"
19     API_KEY = "sk-abc123hardcodedkey"

-----
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
Severity: Medium Confidence: Low
CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608\_hardcoded\_sql\_expressions.html
Location: .\vulnerable_app.py:31:12
30     # DANGEROUS: directly concatenating user input into SQL
31     query = "SELECT * FROM users WHERE username = " + username + " AND password = " + password + ""
32     print("[*] Running query:", query)

-----
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified, security issue.
Severity: High  Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602\_subprocess\_popen\_with\_shell\_equals\_true.html
Location: .\vulnerable_app.py:50:13
```

```
Command Prompt
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
Severity: High Confidence: High
CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
Location: .\vulnerable_app.py:60:11
59     # DANGEROUS: MD5 is easily cracked using rainbow tables
60     return hashlib.md5(password.encode()).hexdigest()
61

>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
Severity: Medium Confidence: Medium
CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
Location: .\vulnerable_app.py:93:23
92     cursor = conn.cursor()
93     cursor.execute("SELECT * FROM users WHERE id = " + str(user_id))
94     return cursor.fetchall()

Code scanned:
Total lines of code: 45
Total lines skipped (#nosec): 0
Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
Total issues (by severity):
  Undefined: 0
  Low: 3
  Medium: 2
  High: 2
Total issues (by confidence):
  Undefined: 0
  Low: 1
  Medium: 3
  High: 3
Files skipped (0):
```